

CSE447

Selected Topics in Computer Security

Spring 2026

Lecture (x)

Vendor & Cloud Risk - Third-Party
Risk Management (TPRM)

Ahmed wageh



The Problem: Why Third-Party Risk Matters

- **The Growing Risk of Third-Party Dependencies**
- Organizations rely heavily on **vendors, SaaS, and cloud providers**
- Third parties often have **access to sensitive data and critical systems**
- A security weakness in a vendor can **compromise the entire organization**
- **Real-World Incidents**
- **Target (2013):** Breach via HVAC vendor
- **SolarWinds (2020):** Supply chain attack affecting 18,000+ organizations
- **Okta (2022):** Breach through support vendor
- **Key Insight**
- **Over 60% of data breaches involve third parties (Ponemon Institute)**

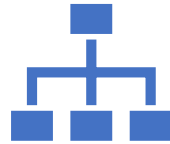


What is Third-Party Risk Management (TPRM)

Definition of TPRM

- **Third-Party Risk Management (TPRM)** is a structured process used to **identify, assess, and manage risks** introduced by external vendors and service providers
- Ensures that third parties meet the organization's **security, compliance, and risk requirements**
- **Why TPRM is Important**
- Vendors introduce **cybersecurity, operational, and compliance risks**
- Organizations remain **responsible for data breaches**, even if caused by vendors
- Required by frameworks such as **ISO 27001 and NIST**
- **ISO 27001 Reference**
- **Annex A 5.19 – 5.22**
Controls for managing **supplier and third-party relationships**





TPRM in the GRC Operating Model

GRC = Governance, Risk, Compliance

- **Governance**
 - Defines **policies, roles, and responsibilities** for managing vendors
- **Risk Management**
 - Identifies, assesses, and treats **third-party risks**
- **Compliance**
 - Ensures vendors meet **security and regulatory requirements** (e.g., ISO 27001, SOC 2)
- **Reporting**
 - Measures performance using **KPIs & KRIs**
 - Reports risk levels to management
- **Key Concept**
 - TPRM is **not a standalone process**
 - It is fully integrated within the **GRC framework**

Policy vs Standard vs Procedure (TPRM Context)

- **1. Policy (WHAT & WHY)**

- High-level rules defined by management
- Example:
 - “All vendors must meet security requirements before onboarding”
-

- **2. Standard (WHAT must be done)**

- Specific and measurable requirements
- Examples:
 - SOC 2 Type II or ISO 27001 required
 - Data encryption (AES-256, TLS 1.2+)

- **3. Procedure (HOW it is implemented)**

Step-by-step execution process

Example:

Submit vendor request
Perform risk assessment
Assign risk tier
Review documents
Approve / Reject

Key Insight

Policy → defines direction

Standard → defines requirements

Procedure → enables execution

Vendor Risk Assessment & Tiering

Vendor Risk Assessment

- The process of evaluating the **risk level of a third-party vendor**
- Evaluates vendor risk **before onboarding and during lifecycle**
- Based on:
 - **Data sensitivity** (PII, financial data, etc.)
 - **Access level** (systems, networks, admin privileges)
 - **Service criticality** (impact on business operations)
- **Vendor Tiering**
- **Tier 1 — Critical Vendors**
- Access to **sensitive data, critical systems, or privileged access**
- Require:
 - SOC 2 Type II
 - ISO 27001
 - Continuous monitoring

Tier 2 — High Risk Vendors

Moderate data access (e.g., SaaS tools)

Require:

- Security assessment
- Periodic reviews

Tier 3 — Low Risk Vendors

Minimal or no sensitive data access

Require:

- Basic contractual controls

Key Insight

Not all vendors are equal —
risk-based classification ensures **efficient and focused security efforts**

Compliance: Verifying Vendor Security

- **Why Compliance Matters**
 - Ensures vendors meet **security and regulatory requirements**
 - Provides **evidence of effective security controls**
 - Reduces organizational risk when working with third parties
- **Key Standards**
 - **SOC 2 Type II**
 - Independent audit over a **period of time (6–12 months)**
 - Evaluates effectiveness of security controls
 - **Type I vs Type II:**
 - Type I → controls exist
 - Type II → controls work consistently



- **ISO/IEC 27001**
 - International standard for **Information Security Management Systems (ISMS)**
 - Covers policies, procedures, and risk management processes
 - Certified by external auditors
- **Important ISO Control**
 - **Annex A 5.20:** Security requirements must be **included in vendor contracts**
- **Red Flags**
 - No SOC 2 report
 - Expired certification
 - Refusal to share audit reports
 - Qualified audit opinion



Case Study: SolarWinds Supply Chain Attack (2020)

- **What Happened?**
- Attackers compromised the **SolarWinds software build pipeline**
- Inserted malicious code into a trusted update (Orion platform)
- Distributed to **18,000+ organizations** including government agencies
- **Why This Matters**
- Organizations trusted a **legitimate vendor update**
- Attack bypassed traditional security controls
- Shows that vendor risk can become **organizational risk instantly**

ISO 27001 Connection

Annex A 5.21 — ICT Supply Chain Security

Requires visibility into how vendors **develop and deliver software**

Focus on:

Secure SDLC

Build pipeline integrity

Code signing controls

Key Lesson

Trusting vendor output is not enough — organizations must **assess vendor processes and security practices**



Cloud Risk & Shared Responsibility Model

- **Cloud Risk in Modern Organizations**
- Organizations rely heavily on **cloud service providers (AWS, Azure, GCP)**
- Misconfigurations and poor access control can lead to **major data breaches**
-
- **Shared Responsibility Model**
- **Cloud Provider (CSP):**
 - Secures infrastructure (hardware, data centers, networking)
- **Customer (Organization):**
 - Responsible for:
 - Data protection
 - Identity & Access Management (IAM)
 - System configurations



- **Real-World Example**
 - **Capital One (2019):** Misconfigured WAF + excessive IAM permissions
 - Result: Data breach affecting millions
 - Cloud provider was **not at fault**
- **ISO 27001 Connection**
 - **Annex A 5.23 (NEW – 2022)**
 - Governs secure use of cloud services
 - Requires clear definition of security responsibilities
- **Key Insight**
 - Moving to the cloud does **not eliminate risk**
 - It **shifts responsibility, not ownership**



Real-World Challenge: GRC vs Development

- **The Conflict**

- Development teams want **speed and fast deployment**
- GRC teams require **risk assessment and compliance checks**

- **Typical Scenario**

- A team wants to onboard a new SaaS tool quickly
- GRC blocks the request until:
 - Risk assessment is completed
 - Security requirements are verified
- Vendor lacks **SOC 2 or security documentation**

- **The Problem**

- Developers see GRC as **slow and restrictive**
- GRC sees developers as **introducing unmanaged risk**

The Solution

GRC should not say “**No**”, but “**Not yet**”

Provide:

Clear requirements

Defined onboarding process

Risk-based decision making

Key Insight

Effective TPRM balances **security** and **business agility**



KPIs vs KRIs in TPRM

- **Key Performance Indicators (KPIs)**
- Measure how well the **TPRM program is performing**
- Examples:
 - % of vendors with valid **SOC 2 Type II reports**
 - % of vendors completing **annual risk assessments**
 - Average time to complete vendor onboarding
- **Key Risk Indicators (KRIs)**
- Measure the **level of risk exposure**
- Examples:
 - Number of vendors with **critical vulnerabilities**
 - Vendors with **expired certifications**
 - Third parties with **excessive access privileges**

Key Difference

KPIs → **Performance of the process**

KRIs → **Level of risk to the organization**

Important Insight

KPI issue = **process problem**

KRI issue = **risk problem**



The TPRM Lifecycle

- **1. Identify**
 - Create a **vendor inventory**
 - Classify vendors based on:
 - Data access
 - System access
 - Business criticality
- **2. Assess & Treat**
 - Perform **risk assessment**
 - Assign vendor tier (Tier 1, 2, 3)
 - Decide on risk treatment:
 - Accept
 - Mitigate
 - Transfer
 - Avoid

3. Monitor

Continuous monitoring of vendors

Track:

- Security posture
- New vulnerabilities
- Breach notifications

4. Report & Improve

Report KPIs & KRIs to management

Apply **continuous improvement (ISO Clause 10)**

Update policies and controls

Key Insight

TPRM is not a one-time activity —
it is a **continuous lifecycle process**



Summary

- **Section 1 — Key Takeaways**
- Third-Party Risk Management (TPRM) is essential due to increasing reliance on **vendors and cloud providers**
- TPRM is integrated within the **GRC Operating Model** (Governance, Risk, Compliance, Reporting)
- The **3-Level Hierarchy** (Policy → Standard → Procedure) ensures effective implementation of vendor security
- **Section 2 — Critical Concepts**
- Not all vendors are equal → use **risk-based tiering**
- Compliance frameworks (**SOC 2, ISO 27001**) provide security assurance
- Cloud security follows a **shared responsibility model**
- **Section 3 — Final Insight**
- Vendor risk = **Organizational risk**
- Security is based on **verification and continuous monitoring**, not trust alone



Questions?



Thank You

